



INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY
(ICDFA) SECURITY POLICY

Compiled by Group 4



Table of Contents

Executive Summary	4
Enterprise Security Policy (ESP)	6
1.1 Purpose	
1.2 Scope	
1.3 Roles and Responsibilities	
1.4 Policy Statements	
1.5 Compliance Requirements	
1.6 Enforcement and Exceptions	
1.7 Definitions and References	
1.8 Version Control and Review	
1.9 Verification and Metrics	
Acceptable Use Policy (AUP)	8
2.1 Purpose	
2.2 Scope	
2.3 Roles and Responsibilities	
2.4 Acceptable Uses	
2.5 Unacceptable Uses	
2.6 Compliance Requirements	
2.7 Enforcement and Exceptions	
2.8 Definitions and References	
2.9 Version Control and Review	
2.10 Verification and Metrics	
Access Control Policy	10
3.1 Purpose	
3.2 Scope	
3.3 Roles and Responsibilities	
3.4 Policy Statements	
3.5 Compliance Requirements	
3.6 Enforcement and Exceptions	
3.7 Procedures	
3.8 Definitions and References	
3.9 Version Control and Review	
3.10 Verification and Metrics	
Data Classification Policy	13
4.1 Purpose	
4.2 Scope	
4.3 Roles and Responsibilities	
4.4 Policy Statements	



4.4.1 Data Classification Levels	
4.4.2 Labeling and Storage	
4.4.3 Access Controls	
4.4.4 Data Transmission	
4.4.5 Data Retention and Disposal	
4.4.6 Third-Party Handling	
4.5 Compliance Requirements	
4.6 Enforcement and Exceptions	
4.7 Procedures	
4.8 Definitions and References	
4.9 Version Control and Review	
4.10 Verification and Metrics	
Incident Response Policy	16
5.1 Purpose	
5.2 Scope	
5.3 Roles and Responsibilities	
5.4 Policy Statements	
5.5 Compliance Requirements	
5.6 Enforcement and Exceptions	
5.7 Definitions	
5.8 Document Version Control	
5.9 Verification and Metrics	
5.10 Incident Classification and Severity Levels	
5.11 Incident Severity Levels	
5.12 Incident Response Phases	
5.13 Communication and Reporting	
Mobile Device Policy	29
6.1 Purpose	
6.2 Scope	
6.3 Roles and Responsibilities	
6.4 Policy Statements	
6.4.1 Device Registration and Management	
6.4.2 Access Controls and Authentication	
6.4.3 Data Protection	
6.4.4 Software Updates	
6.4.5 Network Connectivity	
6.4.6 Physical Security	
6.4.7 BYOD-Specific Requirements	
6.4.8 Usage and Guidelines	
6.5 Compliance Requirements	



6.6 Enforcement and Exceptions	
6.7 Definitions and References	
6.8 Version Control and Review	
6.9 Verification & Metrics	
Cloud Security Policy	36
7.1 Purpose	
7.2 Scope	
7.3 Roles and Responsibilities	
7.4 Policy Statements	
7.5 Compliance Requirements	
7.6 Enforcement and Exceptions	
7.7 Definitions and References	
7.8 Version Control and Review	
7.9 Verification and Metrics	
Physical Security Policy	39
8.1 Purpose	
8.2 Scope	
8.3 Roles and Responsibilities	
8.4 Policy Statements	
8.4.1 Access Control to Facilities	
8.4.2 Equipment Security	
8.4.3 Emergency Procedures	
8.5 Compliance Requirements	
8.6 Enforcement and Exceptions	
8.7 Definitions and References	
8.8 Version Control and Review	
Effective Metrics and Measurement	42
Implementation Strategies and Effectiveness Measurement	43
Training and Awareness	45
Conclusion	47
Appendices	48



Executive Summary

The International Cybersecurity and Digital Forensics Academy (ICDFA)

Security Policy provides a comprehensive framework for safeguarding the Academy's information assets, ensuring regulatory compliance, and supporting the organization's mission in cybersecurity education and research.

Key Elements:

- **Purpose and Scope:**

The policy's main objective is to protect the confidentiality, integrity, and availability of ICDFA's data, systems, and physical assets. It applies to all staff, students, contractors, partners, and third parties who interact with Academy resources.

- **Governance and Responsibilities:**

Clear roles are defined for executive management, IT and security teams, users, vendors, and partners. Everyone shares responsibility for security, with mandatory training and reporting requirements for all.

- **Core Security Policies:**

The document sets out specific policies for:

- **Enterprise Security:** general information security controls, international standards compliance
 - **Acceptable Use:** responsible and lawful use of IT resources
 - **Access Control:** role-based access, least privilege, account lifecycle management
 - **Data Classification:** structured labeling and protection of all data based on sensitivity
 - **Incident Response:** detailed, NIST-aligned procedures for managing breaches and cyber threats
 - **Mobile Device Security:** MDM, encryption, BYOD/CYOD, data protection
 - **Cloud Security:** shared responsibility, vendor assessment, encryption, backup, and recovery
 - **Physical Security:** facilities, equipment, surveillance, emergency procedures
- **Compliance:**
The policy aligns with major international and national standards and laws, including ISO/IEC 27001, NIST, GDPR, HIPAA, PCI DSS, NDPA (Nigeria), and others relevant to the Academy's operations.



- **Enforcement:**
Violations can result in disciplinary action, loss of access, or legal consequences. Exceptions are tightly controlled through formal processes, with periodic review.
- **Verification & Metrics:**
Policy effectiveness is tracked through audits, incident metrics, training completion rates, vulnerability scans, and ongoing risk assessments. Continuous improvement is a focus, with regular policy updates and feedback mechanisms.
- **Training & Awareness:**
A robust, mandatory training and awareness program is in place for all staff, students, and contractors, including threat recognition, secure computing practices, and clear incident reporting procedures.
- **Implementation:**
The policy is implemented through phased deployment, leadership support, regular communication, and incentives for compliance.
- **Continuous Improvement:**
The policy is treated as a living document, reviewed annually or after major changes, with feedback loops and audits to ensure ongoing relevance and effectiveness.

Conclusion:

ICDFA's Security Policy establishes a strong, accountable security culture, combining technical controls, clear procedures, and a human-centric approach to awareness. It is a critical foundation for digital resilience, business continuity, and stakeholders' trust within the Academy's educational and research environment.



1.0. ENTERPRISE SECURITY POLICY (ESP)

1.1. Purpose

This policy defines ICDFA's approach to information on security. Its goal, is to protect the confidentiality, integrity, and availability of Academy data and systems.

1.2. Scope

This policy applies to all staff, students, contractors, and partners who use or manage Academy resources.

1.3. Roles and Responsibilities

- 1.3.1. Executive Management is responsible for approving policies and ensuring that the necessary resources are readily available.
- 1.3.2. The Information Security Team will be responsible for developing, enforcing, and continuously monitoring security controls.
- 1.3.3. Staff and students are expected to follow the requirements, complete training, and promptly report any incidents.
- 1.3.4. Vendors and Partners: Must meet all contracted security obligations when handling academy resources.

1.4. Policy Statements

- At ICDFA, Security is a shared responsibility of everyone
- All sensitive data must be protected in accordance with international standards, such as ISO/IEC 27001 and NIST.
- Access to systems will only be granted on a need-to-know basis and reviewed regularly.
- Across ICDFA, security training is mandatory for all users.
- Regular risk assessments will be carried out to address new risks as they arise.
- Every security incident must be reported immediately.

1.5. Compliance Requirements

This policy aligns with the GDPR, HIPAA (where relevant), PCI DSS, ISO/IEC 27001, and the NIST Cybersecurity Framework.



1.6. Enforcement and Exceptions

Violations may result in disciplinary measures, revoked access, or contract termination. Exceptions must be approved in writing by the Information Security Officer.

1.7. Definitions and References

- Confidentiality: Means preventing unauthorized access or disclosure of data.
- Integrity: This is about making sure data cannot be changed or tampered with without approval
- Availability: Ensuring systems and information are accessible whenever needed.

References: ISO/IEC 27001, NIST Cybersecurity Framework, ICDFA Acceptable Use Policy.

1.8. Version Control and Review:

Document Reference No: ICDFA/ES/SP/2025/01

Effective Date: August 2025

Next Review Date: August 2026

Review Schedule: Annually or when triggered, by regulatory or operational changes.

Policy Owner: Chief Information Security Officer (CISO)

Approved By: Board of Directors and Chief Information Security Officer (CISO)

Version: v1.0

1.9. Verification and Metrics

- 1.9.1. Audits and compliance checks will be used to verify adherence
- 1.9.2. Security training completion will be tracked
- 1.9.3. The number and severity of reported incidents will be monitored.
- 1.9.4. Risk-reduction trends will be measured over time to confirm progress.



2.0. ACCEPTABLE USE POLICY (AUP)

2.1. Purpose

This policy explains the proper use of ICDFA's IT resources. Its purpose is to ensure these resources are used responsibly, lawfully, and in line with the Academy's mission.

2.2. Scope

It applies to all staff, students, contractors, and visitors with access to ICDFA systems.

2.3. Roles and Responsibilities

2.3.1. The ICT Department is responsible for maintaining the IT infrastructure and enforcing security controls.

2.3.2. Users: all users are expected to use sources responsibly and promptly report any misuse.

2.3.3. Supervisors are responsible for ensuring their teams understand and comply with this policy.

2.4 Acceptable Uses

- Accessing Systems: For academic, research, and official purposes.
- Personal Use: limited internet or email use is allowed, provided it does not interfere with productivity or security.
- Software use: only authorized and approved software may be installed or used.

2.5 Unacceptable Uses

- Passwords and security: sharing login details or trying to bypass security controls.
- Illegal or harmful content: Downloading, storing, or sharing offensive, illegal, or pirated materials.
- Unauthorized software: installing unauthorized software/applications or connecting unapproved devices.
- Misuse of resources: using Academy resources/systems for personal businesses, political activities, or fraud activities



- System interference: scanning or disrupting academy networks or systems.

2.6 Compliance Requirements

Users must comply with GDPR for personal data, respect copyright laws, and comply with relevant national cybersecurity regulations.

2.7 Enforcement and Exceptions

Breaches of this policy may result in disciplinary actions, revoked laws, or termination. Any exceptions must be formally requested in writing and approved by the ICT Director.

2.8 Definitions and References

- IT Resources: covers all systems, networks, devices, and services owned or managed by ICDFA.
- User: This refers to any person authorized to access and use the ICDFA academy systems.
- References: ICDFA Enterprise Security Policy, ISO/IEC 27001, GDPR.

2.9 Version Control and Review

Document Reference No: ICDFA/AU/SP/2025/01

Effective Date: August 2025

Next Review Date: August 2026

Review Schedule: Annually or when triggered by regulatory or operational changes.

Policy Owner: Chief Information Security Officer (CISO)

Approved By: Board of Directors

Version: v1.0

2.10 Verification and Metrics

- Audits and system log reviews will be used to verify compliance.
- The number of policy violations and disciplinary cases will be timed
- Feedback from staff and student surveys will be collected.
- Risk and IT misuse incidents will be monitored for reduction over time



3.0. ACCESS CONTROL POLICY

3.1. Purpose.

The purpose of this policy is to ensure that access to the International Cyber Security and Digital Forensics Academy (ICDFA) systems, applications, and data is granted, managed, and revoked in a secure, consistent, and auditable manner. The policy ensures that only authorized individuals have access based on their roles, responsibilities, and business needs.

3.2. Scope

This policy applies to

- 3.2.1. All employees, contractors, students, and third-party vendors accessing ICDFA systems or data.
- 3.2.2. All electronic systems, including servers, databases, applications, and cloud services.
- 3.2.3. Physical access to IT assets and facilities when it impacts information security.

3.3. Roles and Responsibilities

- 3.3.1. Information Security Manager (ISM): Oversees access control strategy, approves exceptions, and ensures compliance with this policy.
- 3.3.2. System Administrators: Implement, monitor, and maintain access controls, including account creation, modification, and revocation.
- 3.3.3. Department Heads and Managers: Review and approve access requests based on job duties; identify role changes requiring access modifications.
- 3.3.4. Employees and Users: Comply with assigned access privileges, maintain account confidentiality, and report suspicious activity.
- 3.3.5. Audit and Compliance Team: Conduct regular access reviews, log inspections, and audit compliance against regulatory standards.

3.4. Policy Statements

- Principle of Least Privilege: Users will be granted the minimum access necessary for their roles.
- Role-Based Access Control (RBAC): Access rights are assigned based on clearly defined roles; any deviation must follow formal approval procedures.
- Authentication Requirements: All users accessing sensitive systems must use strong passwords and multi-factor authentication (MFA).



- User Account Lifecycle Management:
 - a. New accounts require formal approval.
 - b. Accounts must be reviewed quarterly to remove unnecessary privileges.
 - c. Accounts must be disabled within 24 hours of termination or role change.
- Privileged Access: Access for system administrators or high-level users is strictly controlled, monitored, and logged.
- Remote Access: VPN or secure connections must be used; remote access is restricted to authorized personnel.
- Third-Party Access: Vendors and contractors must have access limited to the minimum required and must sign agreements specifying security responsibilities.
- Logging and Monitoring: All access activities must be logged. Unauthorized access attempts must be investigated.

3.5. Compliance Requirements

- SO/IEC 27001 A.9 (Access Control)
- NIST Cybersecurity Framework (PR.AC – Access Control)
- GDPR Article 32 – Security of Processing
- HIPAA Access Control Standard (45 CFR §164.312(a))
- PCI DSS Requirement 7 – Restrict Access to Cardholder Data

3.6. Enforcement and Exceptions

3.6.1. Any violation of this policy may result in disciplinary action, including revocation of access, suspension, or termination.

3.6.2. Exceptions must be documented, justified, and approved by the ISM and will be reviewed every 90 days.

Procedures

- Access Request Procedure: Employees submit requests through the IT Service Management system, reviewed by the manager, approved by ISM, and implemented by system administrators.
- Access Review Procedure: Quarterly review reports generated by IT, reconciled with department heads, and corrective actions taken for discrepancies.



- Incident Procedure: Unauthorized access attempts are logged, escalated to the ISM, and investigated; corrective actions are documented.

3.7. Definitions and References

- MFA (Multi-Factor Authentication): Two or more verification methods to confirm identity.
- RBAC: Access method where permissions are assigned based on roles, not individuals.
- Privileged Account: Account with elevated rights, such as system administrator or database admin.
- Access Review: Scheduled review to ensure only authorized users have access

3.8. Version Control and Review

Document Reference No: ICDFA/AC/SP/2025/01

Effective Date: August 2025

Review Schedule: Annually or after major system changes.

Policy Owner: IT Security Officer

Approved By: Board of Directors and Chief Information Security Officer (CISO)

Version: v1.0

3.9. Verification and Metrics

- 80% of user accounts are reviewed quarterly.
- Average time to revoke accounts post-termination.
- Number of unauthorized access incidents detected.
- 96% compliance with MFA deployment across all sensitive systems



4.0. DATA CLASSIFICATION POLICY

4.1. Purpose

The purpose of this policy is to establish a structured approach for classifying, handling, and protecting ICDFA data according to its sensitivity, regulatory requirements, and potential business impact. Correct data classification ensures appropriate security controls are applied and legal/regulatory obligations are met.

4.2. Scope

This policy applies to:

- 4.2.1.** All digital and physical data created, stored, processed, or transmitted by ICDFA.
- 4.2.2.** All employees, contractors, and third-party service providers handling ICDFA data.
- 4.2.3.** All devices and systems that store, transmit, or process ICDFA data.

4.3. Roles and Responsibilities

- 4.3.1.** Data Owners: Determine classification levels for data under their control and approve handling requirements.
- 4.3.2.** Data Custodians (IT/Technical Staff): Implement security measures to protect classified data, including encryption, backups, and access restrictions.
- 4.3.3.** Employees and Users: Handle data in accordance with classification rules and report incidents of misclassification or unauthorized disclosure.
- 4.3.4.** Compliance Team: Ensure data classification aligns with regulatory requirements, perform audits, and provide guidance on handling requirements.

4.4. Policy Statements

- Data Classification Levels:
 - a. Public: Information intended for public dissemination (e.g., press releases, public training materials).
 - b. Internal: Information limited to internal staff and stakeholders; disclosure could inconvenience operations but is not critical.
 - c. Confidential: Sensitive information such as student records, internal reports, research data. Unauthorized disclosure may cause significant operational or reputational damage.



d. Restricted: Highly sensitive information, including personally identifiable information (PII), financial data, forensic case evidence, or passwords.

e. Unauthorized disclosure could result in severe legal, financial, or operational consequences.

- Labeling and Storage: All data must be labeled according to its classification and stored in designated secure locations. Confidential and Restricted data must be encrypted at rest and in transit.

- Access Controls: Only authorized users with legitimate business need may access Confidential and Restricted data.

- Data Transmission: Sensitive data may only be transmitted over secure channels (VPN, encrypted email, or secure file transfer protocols).

- Data Retention and Disposal: Classified data must be retained according to legal, regulatory, or operational requirements. End-of-life data must be destroyed securely (shredding for paper, secure deletion for digital files).

- Third-Party Handling: Vendors handling Confidential or Restricted data must comply with ICDFA's classification standards and contractual obligations.

4.4. Compliance Requirements

- ISO/IEC 27001 A.8 – Asset Management
- NIST CSF ID.AM & PR.DS – Data Security
- GDPR Articles 5 & 32 – Data Protection Principles & Security of Processing
- PCI DSS – Protect Cardholder Data

4.5. Enforcement and Exceptions

- Mishandling or misclassification may result in disciplinary action, up to termination.
- Exceptions must be approved by the Data Owner and Compliance Team and reviewed every 90 days.

Procedures

- Classification Procedure: Data owners classify new data during creation; IT enforces labeling standards.

- Access Procedure: Only approved users may access Confidential/Restricted data; access logs are monitored.

- Incident Procedure: Misclassification or data breach incidents reported to ISM



immediately; corrective action documented.

- Disposal Procedure: Data is securely disposed of at the end of its lifecycle, with documentation of destruction for audits.

4.6. Definitions and References.

- PII (Personally Identifiable Information): Data that can identify an individual, such as name, email, or ID number.
- Encryption: Conversion of data into an unreadable format to protect it from unauthorized access.
- Data Owner: Individual responsible for determining classification and handling requirements for a specific dataset.

4.7. Version Control and Review

Document Reference No: ICDFA/DC/SP/2025/01

Effective Date: August 2025

Next Review Date: August 2026

Review Schedule: Annually or after changes in laws/regulations

Policy Owner: Information Security Officer

Approved By: Board of Directors and Chief Information Security Officer (CISO)

Version: v1.0

4.8. Verification and Metrics

- 100% of data properly classified and labeled.
- Number of incidents of misclassification or unauthorized disclosure.
- Encryption compliance rate for confidential and restricted data.
- 92% of employees trained on data classification standards.



5.0. INCIDENT RESPONSE POLICY

5.1. Purpose

The purpose of this policy is to have a defined approach for identifying, controlling, and mitigating information security incidents. ICDFA seeks to protect information assets from incidents, enable timely responses and recoveries, and meet compliance and policy obligations. This policy aims to minimize the impact of incidents on ICDFA's information assets, ensure timely response and recovery, and comply with relevant regulatory requirements.

5.2. Scope

The policy applies to all ICDFA systems, networks, applications, data, personnel, and third-party services.

5.3. Roles and Responsibilities

5.3.1. Incident Response Team (IRT): This team will lead the incident response, coordination, and management of investigation, containment, eradication, recovery, and post-incident review.

5.3.2. IT Security Manager: Oversees the incident response program, ensures training is conducted, and shares information within the cybersecurity teams.

5.3.3. All Employees: They are required to report any suspicious activities immediately to the IRT or IT Security Manager.

5.3.4. Department Heads: They are to support incident response handling efforts within their respective units and ensure employee compliance.

5.3.5. Communication Manager: Manages all communications for the incident, including internal and external communications, serving as the primary point of contact with regulators and media as needed.

5.4. Policy Statements

- ICDFA shall implement and maintain the necessary incident response capabilities to ensure a swift detection, analysis, and reaction to potential security concerns.
- All employees must be trained and regularly prompted towards the mindful and timely reporting of incidents.



- Incidents must be reported using predefined reporting structures.
- The Incident Response Team shall classify all reported incidents by risk impact and severity and utilize predefined criteria to prioritize incidents.
- Incident handling procedures must contain the following actions: limit damages to containment, eradicate the root cause of the issue, perform recovery actions on the system, and document lessons learned.
- ICDFA shall maintain an incident log that contains all reported incidents and actions undertaken, as well as the outcome of those actions.
- All actions taken for incident response will comply with the applicable laws, regulations, and contracts.
- Regular incident response drills and exercises shall be conducted to ensure program readiness and overall effectiveness.

5.5. ICDFA Incident Compliance Requirements

This policy shall comply with the following regulatory, legal, and industry requirements:

1. Data Protection and Privacy

- Ensure and maintain appropriate security for personal data, including student records, examination data, and staff information
- Ensure compliance with the Nigeria Data Protection Act (NDPA 2023) and any applicable regional or international data privacy laws.
- Ensure prompt data breach reporting to affected students, staff, and regulators (Nigeria Data Protection Commission: NDPC) within the mandated legal timeframes.

2. Educational/Institutional Compliance Obligations

- Ensure the confidentiality, integrity, and availability of academic records, assessment results, and certification processes are protected.
- Ensure no compromise of academic integrity or data manipulation due to incident handling.
- Ensure compliance with accrediting and educational oversight bodies' requirements.



3. Cybersecurity Standards and Frameworks

- Ensure policy aligns with relevant industry standards, frameworks and best practices, e.g ISO/IEC 27001, ISO/IEC 27035, NIST 800-61, NDPA, CYBERCRIMES (PROHIBITION, PREVENTION, ETC.) ACT, 2015, etc.
- **Third-Party and Vendor Compliance**
- Ensure all third parties that provide cloud services, Learning Management Systems (LMS), and IT support comply with security and incident reporting obligations.
- Ensure that the Data Processing Agreements (DPAs) and Service Level Agreements (SLAs) define clear roles and responsibilities during incidents.

4. Legal and Forensic Readiness

- Ensure accurate preservation of digital evidence in accordance with forensic and legal standards to enable an effective chain of custody for investigations.
- Ensure maximum cooperation with law enforcement and regulators when legally required.

5. Training and Awareness

- Ensure appropriate periodic training of staff, students, and contractors on how to recognize and report incidents.
- Ensure detailed and up-to-date documentation of awareness programs as evidence of compliance during audits.

6. Testing and Continuous Improvement

- Ensure regular incident response exercises to stay updated and to meet compliance and audit requirements.
- Ensure regular updates of the Incident Response Plan (IRP) based on lessons learned, regulatory updates, and audit findings.

5.6. Enforcement and Exceptions

Enforcement

Failure to comply with this policy, including the failure to report a suspected incident, may result in disciplinary action, up to and including termination of employment or cancellation



of contracts or affiliations. Systematic, willful, or repeated noncompliance will trigger a formal investigation. In addition, violations may expose both the individual and the Academy to legal or financial penalties. All employees, contractors, and affiliates are expected to adhere to this policy to ensure the security and integrity of the academy's information systems.

Exceptions

The purpose of this exception is to outline a method for obtaining an exception to compliance with the incident response policy to mitigate risk and satisfy business requirements at ICDFA. It applies to all consumers of ICDFA's Information and Communication Technology (ICT) resources and systems.

Exception Process

- I. Requests for cybersecurity exceptions must be made in writing to ICDFA's Security Manager in accordance with the requirements of this Policy.
- II. ICDFA's Security Architect will review all requests for exceptions in consultation with the requester and other key stakeholders.
- III. An exception may be granted by the Security Manager of ICDFA for non-compliance with this policy or standard resulting from:
 - a. Implementation of a solution with equivalent protection to the requirements in the policy or standard.
 - b. Implementation of a solution with superior protection to the requirements in the policy or standard.
 - c. Impending retirement of a system.
 - d. Inability to implement the policy or standard due to some limitation, which could be a technical constraint, a business limitation, or a statutory requirement.

Exception Requirements

Requests for exceptions to cybersecurity standards must be submitted to ICDFA's Security Manager, and they should contain the following information:

- a. A description of the instance;
- b. A description of the required exception;



- c. The reason the exception is required.
- d. How long the exception is needed and a list of actions with time frames to implement compliance before the exception expires; and
- e. A completed risk assessment, including a description of an alternative cybersecurity control (if one is proposed). *(See the Appendix for the Sample Exception Request Form.)*

In accordance with ICDFA's Risk Management Framework, a request for an exception must include a risk assessment to determine the level of risk to which the University is exposed if the exception is granted. The risk assessment will take into account any alternative cybersecurity controls that may be applicable to ensure the managed risk level remains within the Academy's risk appetite.

Exceptions are reviewed on a case-by-case basis, and their approval is not automatic. Exceptions granted will be for a specific period, not exceeding one year. Upon expiration of the exception, an extension of the exception may be requested if it is still required.

5.7. Definitions

- Information Security Incident: A violation or imminent threat of violation of a security policy, acceptable use policy, or standard security practice. Examples include data breaches, malware infections, unauthorized access attempts, or denial-of-service attacks.
- Information Assets: Any information or data, along with the systems, networks, applications, and infrastructure used to process, store, and transmit it. This includes all hardware, software, intellectual property, and business-critical data owned or managed by ICDFA.
- Incident Response Team (IRT): A designated group of individuals responsible for leading the coordinated response to all information security incidents. The IRT includes members with diverse skills in IT security, legal, human resources, and communications.
- Incident Handling: The predefined process for managing an information security incident, which includes the stages of detection, analysis, containment, eradication, recovery, and post-incident review.



5.8. Version Control and Review

Document Reference No: ICDFA/IR/SP/2025/01

Effective Date: August 2025

Next Review Date: August 2026

Review Schedule: Annually or after changes in laws/regulations

Policy Owner: Incident Management Team Lead

Approved By: ICDFA Director

Version: v1.0

5.9. Verification and Metrics

The policy effectiveness of the associated Incident Response Plan will be measured through these different methods:

- Compliance Metrics: Internal audits, self-assessments, and automated monitoring tools will be used to monitor and assess compliance.
- Incident Metrics: Frequency, severity, response time, and root causes of the incident.
- Awareness and Understanding: Periodical surveys, quizzes, training completion rates, and drills will be planned and carried out.
- Exception Tracking: The number and type of approved exceptions and periodic reviews will be carried out to track exceptions and their application.
- Risk Reduction Metrics: Pre/post-risk assessments, vulnerability scans, and a reduction in incidents
- Lessons Learned Metrics: Implementation of improvements post-incident review.

5.10 INCIDENT CLASSIFICATION AND SEVERITY LEVELS

1. Incident Classification Categories

a. Malware and Ransomware

Incidents involving malicious software affecting ICDFA's network, systems, or data,



including viruses, worms, and ransomware encrypting digital forensic or cybersecurity data.

b. Unauthorized Access and Privilege Misuse

All attempts at, or successful unauthorized access to, ICDFA systems, digital forensics case files, sensitive research data, or administrative environments by internal or external actors.

c. Phishing and Social Engineering

All attempts to deceive ICDFA personnel into revealing credentials, sensitive information, or performing unauthorized actions through fraudulent communications.

d. Denial of Service (DoS/DDoS) Attacks:

Disruptions impacting ICDFA's online resources, research platforms, or digital forensic tools due to flooding or overwhelming traffic.

e. Data Breach and Data Exfiltration

Unauthorized disclosure, access, or transmission of ICDFA's confidential research, training materials, or personal data of staff and students.

f. System and Network Intrusions

g. Malicious penetration attempts or breaches targeting ICDFA's IT infrastructure, including forensic lab systems or educational platforms.

h. Insider threat risks from ICDFA staff, contractors, or affiliates that intentionally or accidentally compromise security or breach protocols.

i. Policy Violations: Non-compliance with ICDFA's established security policies, such as misuse of IT resources or failure to follow access control procedures.

j. Physical Security Incidents: Unauthorized physical access to ICDFA premises, data centers,

k. forensic labs, or hardware that may jeopardize information security.



5.11 Incident Severity Levels

Severity Level	Description	Impact	Response Priority
Critical (Level 1)	Incident directly disrupting critical ICDFA operations, such as forensic investigations, training delivery, or access to research data. Includes major data breaches or incidents risking accreditation or legal compliance.	Severe impact on confidentiality, integrity, or availability of key assets; potentially catastrophic reputational or legal harm.	Immediate 24/7 response, full Incident Response Team activation, and executive notification.
High (Level 2)	Significant incidents affecting important systems, sensitive data, or research projects with potential for escalation. E.g., targeted cyberattacks and ransomware outbreaks in a lab environment.	Notable operational disruption or regulatory exposure; requires rapid intervention.	Prompt response within hours; senior management and affected departments informed.
Medium (Level 3)	Incidents causing limited disruption or exposure, such as contained malware infections, phishing attempts targeting staff, or isolated policy breaches.	Moderate impact on operations or data security; manageable without external reporting.	Response during standard hours; ongoing monitoring and remediation.

Low (Level 4)	Minor incidents like failed phishing attempts, accidental data disclosure with no material impact, or minor policy non-compliance.	Minimal operational or reputational impact.	Handled as part of routine security activities; awareness training reinforced.
---------------	--	---	--

5.12 INCIDENT RESPONSE PHASES

Since ICDFA is an educational institution based in the Nigerian environment with students across Africa, its Incident Response Process shall follow the NIST SP 800-61 and ISO/IEC 27035 lifecycle, adapted for compliance with the Nigeria Data Protection Act (NDPA 2023) for safeguarding student, staff, and institutional data.

Phase 1 – Preparation

- Deploy essential tools (e.g., Endpoint Detection & Response, forensic tools, SIEM) for prompt incident response handling.
- Develop, maintain, and regularly update incident response policy playbooks
- Define clear roles and responsibilities for proper incident handling.
- Conduct regular employee awareness training (including phishing simulations).
- Establish clear incident reporting and escalation paths for effective handling of incidents to avoid confusion.

Phase 2 – Detection and Analysis

- Continuously monitor systems, learning platforms, and networks to detect anomalies.
- Analyze the affected system or network for potential impact.
- Review and analyze alerts, malware, and network traffic, using tools like a SIEM system for real-time analysis.



- Determine the type and severity of the attack.
- Validate incidents and classify them by type and severity/impact.
- Document the evidence of incident timelines for accurate detection analysis to limit damage.
- Preserve log evidence to maintain the chain of custody for potential investigation

Phase 3 – Containment

The following containment actions shall be implemented immediately and in the long term to minimize disruptions to academic and administrative operations.

Short-Term Containment

- Isolate the affected system/network to avoid it spreading.
- Implement temporary network segmentation to prevent lateral movement.
- Disable or lock down the affected account and block malicious traffic to preserve evidence.

Long-Term Containment

- Implement continuous monitoring and auditing mechanisms to detect and investigate suspicious activities that could indicate unauthorized access or data breaches.
- Implement stricter access controls to the digital environment, including the student portal, websites, etc.
- Ensure that all remote access activities are properly logged and monitored.
- Ensure effective security monitoring through an in-house or outsourced Security Operations Center (SOC).
- Organize regular training and awareness programs to equip staff with the right skill set and tools, such as a Security Information and Event Management (SIEM) solution for cyber monitoring.
- Deploy automated detection tools to facilitate the early detection of cyber incidents.



Phase 4 – Eradication

Steps to remove the root cause of the incident include:

- Delete confirmed malware and clean the system using specialized cleaning software approved by the IT lead.
- Close exploited vulnerabilities and disconnect the affected system from the network if necessary.
- Evicting unauthorised users and accounts

Patching systems and reinstalling systems where necessary.

Phase 5 – Recovery

- Establish criteria for recovery initiatives.
- Establish and implement the process of restoring systems, services, and data to normal operations.
- Establish and implement a step-by-step procedure for data restoration and for resuming academic and administrative services.
- Validate that restored systems are free from compromise.
- Monitor systems for any signs of lingering issues
- Monitor the affected system to ensure it is free from harm.
- Conduct a simulation for every stage of the incident life cycle.
- Ensure that the simulation and decision-making are effective during a crisis.
- Evaluate responses for the challenging simulation for improvement

Phase 6 – Lessons Learned

- Implement a comprehensive review process involving critical stakeholders.
- Detailed documentation of lessons learned
- Hold structured review meetings where critical issues in each stage of the incident response are discussed, e.g., loss, public view, clients' view, lessons learned, and what to improve.



- Conduct a gap assessment to identify gaps in processes, tools, training, and the incident response playbook.
- Incorporate lessons learned into staff and student awareness programs to improve resilience.

5.13 COMMUNICATION AND REPORTING

Incident Reporting:

- a) Staff, students, and the academy affiliates must report any suspicious activity they observe and any cybersecurity incidents impacting them.
- b) The reporting should be done by filling out and submitting the Security Incident Form through the IT Help Desk page on the Academy Website (Portal).
- c) For critical or active threats, the person should call the dedicated hotline of the security team.

Contents of a Report

- a) Name and Contact Information of a Reporter
- b) Description of suspicious activity or event
- c) Affected system(s), application(s), or data
- d) Date/time the issue was noticed
- e) Supporting details to give more information or clarity of the incident.

A no-blame culture will be adopted to encourage quick and transparent reporting.

Incident Triage to Resolution

- a) The IT Help Desk should log all reports and notify the on-call Incident Response Team.
- b) The Incident Response Team will conduct an analysis of the report, assess its severity, and then the Security Manager will determine if it constitutes a major security event based on the IRT's recommendation.
- c) The security manager will communicate with the academy management/leadership of the event within an hour of the decision that it is a major security event.



- d) Status will be monitored and updated at defined intervals and also updated as to actions taken. The next steps and needs/blockers will also be communicated.

External Communication and Notification

The security manager, in collaboration with and consultation from the legal team and the head of communications (HOC), may approve external communications where necessary.

Stakeholder Notification:

- a) Legal & Regulatory Compliance: The legal team and DPO will ensure compliance with laws and the stipulated timelines for regulatory compliance frameworks and standards.
- b) Law enforcement agencies may be contacted if criminal activity is suspected.
- c) Insurance providers will be notified by the finance department when there is a need that applies to the policy requirements.
- d) Partners and affiliates will be notified in accordance with regulatory and contractual obligations.

Public Communication:

- a) All public statements and communications to affected individuals will be managed solely by the Communications Team, guided by the CISO and Legal Counsel.
- b) No other persons are authorized to discuss the incident outside the academy.

All incident-related information must be treated as confidential and sensitive and should be shared only on a need-to-know basis to protect the investigation, privacy, and organizational reputation.

Post-Incident Reporting

- a) Technical Report: The security team documents a detailed timeline, root cause, and corrective actions.
- b) Executive Summary: The security manager will deliver a non-technical report to the academy leadership, highlighting business impact and lessons learned.
- c) Post-incident Review: A formal debrief with stakeholders that will capture lessons learned to improve the future Incident Response Plan and training.



6.0. MOBILE DEVICE POLICY

6.1. Purpose

The purpose of this policy is to establish security requirements for mobile devices used to access, store, process, or transmit ICDFA resources, including data, systems, and networks. This policy aims to mitigate risks associated with mobile devices, such as data loss, unauthorized access, malware, and physical theft, while supporting productivity and flexibility for users. It ensures the protection of sensitive information, aligns with organizational objectives in cybersecurity education and forensics, and promotes a balance between security and usability.

6.2. Scope

This policy applies to all ICDFA employees, faculty, students, contractors, and third-party users who use mobile devices to access ICDFA resources.

6.2.1. It covers all mobile devices, including smartphones, tablets, laptops, and wearables.

6.2.2. This includes devices that are organization-owned (Corporate-Owned Personally Enabled—COPE).

6.2.3. Personally owned (Bring Your Own Device – BYOD).

6.2.4. Choose-your-own-device (CYOD).

The policy encompasses devices accessing the ICDFA network, email, cloud services, learning management systems, research data, and forensic tools. It does not apply to non-mobile endpoints such as desktop computers.

6. 3. Roles and Responsibilities

- Information Security Officer (ISO)—Responsible for developing, maintaining, and reviewing this policy, overseeing compliance audits, approving exceptions, and coordinating incident response related to mobile devices.
- IT Department/Administrators—Implement and enforce technical controls, such as Mobile Device Management (MDM) systems, and manage device enrollment, configuration, and monitoring. In charge of remote wipes, data recoveries, and training and support.
- Users (employees, faculty, students, and contractors)—comply with policy requirements, report lost or stolen devices immediately, maintain device security



such as passwords and updates, and participate in training and awareness programs.

- Executive Leadership—Provide endorsement and resources for policy implementation, review metrics and effectiveness reports, and ensure alignment with ICDFA's strategic objectives.
- Human Resources (HR)—Handle disciplinary actions for non-compliance and integrate policy acknowledgement into onboarding and contracts.
- Compliance Officer – Monitor adherence to regulatory requirements and conduct periodic reviews.

6.4. Policy Statements

Mobile devices must be managed to protect ICDFA's information assets while enabling educational and operational activities. The following statements outline core requirements:

1. Device Registration and Management

- All mobile devices accessing ICDFA resources must be registered in the asset register and enrolled in the ICDFA MDM system.
- Organization-owned devices will be issued with pre-configured security settings, while BYOD/CYOD devices require user consent for MDM enrollment, which may include monitoring and remote management.
- Devices must support and enable hardware-backed security features such as encryption and secure boot.

2. Access Controls and Authentication

- Devices must use strong authentication methods, including multifactor authentication for ICDFA accounts and biometric options where available.
- Auto-lock must be enabled after 5 minutes of inactivity, with a maximum of 10 failed attempts before the account is temporarily blocked.
- Users must not jailbreak, root, or evade security features.

3. Data Protection

- All data on mobile devices must be encrypted at rest and in transit using AES-256 encryption and VPN for Wi-Fi connections.



- Sensitive data (as defined in ICDFA's data classification policy) must not be stored on personal devices unless authorized.
- Backup must be encrypted and performed via approved ICDFA services. Personal backups such as iCloud or Google Drive are prohibited for ICDFA data.

4. Software Updates

- Devices must run the latest supported OS and application, with automatic updates enabled where possible
- Only approved apps from vetted sources may be installed. Third-party apps must undergo mobile application vetting (MAV) for security risks.
- Anti-malware and Mobile Threat Defense (MTD) software must be installed and kept active.

5. Network Connectivity

- Disable unnecessary wireless features such as Bluetooth or WIFI when not in use. Use ICDFA's VPN for all remote access to resources.
- Avoid public Wi-Fi connections when using devices containing sensitive data from ICDFA. Devices must prompt for user confirmation before connecting to new networks.

6. Physical Security

- Devices must not be left unattended in public or unsecure areas. Use physical locks or secure storage when necessary.
- In case of loss or theft, users report immediately to IT for remote wipe activation.
- Devices accessing ICDFA resources must permit remote wipe capabilities by the IT department in case of loss or theft.

7. BYOD-Specific Requirements

- BYOD is allowed only with ISO approval. Users must sign an acknowledgement of risks and responsibilities.
- ICDFA data on BYOD devices will be segregated in a secure workspace, with no mixing of personal and organizational data.



8. Usage and guidelines

- Devices must not be used for illegal activities or in violation of ICDFA's Acceptable Use Policy.
- Users must be trained on recognizing phishing, malware, and other threats specific to mobile environments.

6.5. Compliance Requirements

This policy ensures alignment with relevant laws, regulations, and standards with a deep focus on mobile-specific requirements. ICDFA, as an international academy handling personal data, forensic information, and potentially payment or health-related data in training scenarios, must comply with multiple regulatory policies and frameworks. The detailed mapping of compliance obligations is as follows.

General Data Protection Regulation (GDPR). This requires technical and organizational measures to protect personal data on mobile devices, such as encryption, pseudonymization, and the ability to remotely wipe devices in case of loss. Data minimization principles mandate that only necessary data is stored on devices with user consent for processing.

It also emphasizes breach notification within 72 hours if personal identification information (PII) is compromised. ICDFA must conduct a data protection impact assessment for high-risk mobile uses such as accessing students' records.

Health Insurance Portability and Accountability Act (HIPAA). In circumstances where ICDFA handles protected health information (PHI), for example, in forensic training or students' leave requests, mobile devices must include encryption, access controls, audit logs, and remote wipe capabilities. The security rule requires risk analyses for mobile devices and no unprotected PHI storage.

Therefore, ICDFA users' devices must auto-lock, and users must not use personal apps for transferring PHI.

Payment Card Industry Data Security Standard (PCI-DSS). Cardholder information must be encrypted and kept off mobile devices for any payment processing, such as course fees. Secure mobile payment apps are required with controls against skimming and malware.

However, PCI-DSS applies to ICDFA if users' devices accept payments, mandating network segmentation and regular vulnerability scans.



Nigeria Data Protection Act (NDPA). This act provides a comprehensive legal framework for both domestic and international organizations operating in Nigeria to comply with data protection requirements. Since ICDFA is Nigerian-based and handles Nigerian students' personal information, it must adhere to the requirements of this act, for example, breach notification within 72 hours.

Sarbanes-Oxley Act (SOX). This ensures internal controls for financial reporting in case of mobile access to financial systems, for example, budgeting apps. It emphasizes audit trails, access restrictions, and risk assessments to prevent fraud. ICDFA users' devices must be part of SOX-compliant controls to maintain data integrity.

Gramm-Leach-Bliley Act (GLBA). Since ICDFA handles financial data of students or partners, it requires safeguards like encryption and access controls on mobile devices. Annual risk assessments and a written information security program must include mobile threats.

NIST cybersecurity framework. Framework and SP 800-124 Recommends centralized MDM, encryption, strong authentication, and threat monitoring for mobile devices. This aligns with the Identify, Protect, Detect, Respond, and Recover functions.

ISO/IEC 27001. Annex A.8.1 requires protection of user endpoint devices through policies on mobile use, including secure configuration, access controls, and teleworking safeguards.

CIS Critical Security Controls. The Mobile Companion Guide emphasizes inventory of devices, secure configurations, continuous vulnerability management, and controlled use of administrative privileges.

ICDFA will monitor regulatory updates annually and adjust the policy accordingly.

6.6. Enforcements and Exceptions.

Enforcement

- Violations will be investigated by the ISO and may lead to disciplinary actions, including warnings, suspension of access, termination, or legal consequences, depending on severity.
- The IT team will monitor compliance through MDM reports, audits, and incident logs.
- Repeated non-compliance will escalate to HR.



Exceptions

- Exceptions must be requested in writing to the ISO, justified by business need, and must include compensating controls such as additional monitoring.
- Approved exceptions will be documented, reviewed annually or as needed, and limited in duration.

No exceptions for core requirements like encryption or reporting of lost devices. All exceptions must be carefully considered, looking at the risk and impact, before approval.

6.7. Definitions and References

Definitions

- Mobile Device—Portable computing devices such as smartphones, tablets, or laptops capable of wireless connectivity.
 - MDM (Mobile Device Management)—a system for configuring, monitoring, and securing mobile devices
 - BYOD (Bring your Own Device)—Use of personal devices for organizational access
- COPE (Corporate-Owned Personally Enabled)—Devices owned by the organization and assigned to different users.
- CYOD (choose-your-own-device) – A mobile device ownership model where users select a device from a pre-approved list provided by ICDFA, which owns and manages it with security settings and MDM enrollment, allowing limited personal use per the Acceptable Use Policy.
 - Mobile Threat Defense (MTD)—Tools for detecting and responding to mobile-specific threats.

References

- ICDFA Acceptable Use Policy, Access Control Policy, Data Classification Policy, and Incident Response Policy.
- NIST SP 800-124 Rev. 2: Guidelines for managing the security of mobile devices.
- ISO 27001: Remote working (Annex A.6.7)



- CIS Controls v8 Mobile Companion Guide.

6.8. Version Control and Review

Document Reference No: ICDFA/MD/SP/2025/01

Effective Date: August 2025

Review Schedule: Annually or when new cloud services are adopted or significant changes occur in existing cloud environments.

Policy Owner: ICDFA Information Security Officer (ISO)

Approved By: Board of Directors and Chief Information Security Officer (CISO)

Next Review Date: August 25, 2026

Version: v1.0

6.9. Verification & Metrics

- Security Awareness Training: Regular security awareness training will be provided to students and faculty.
- Security Incident Reporting: Security incidents will be tracked and reported to identify areas for improvement.

Audit & Review

- Regular Audits: Regular audits will be conducted to ensure compliance with this policy.
- Policy Review: This policy will be reviewed annually or as needed.



7. 0. CLOUD SECURITY POLICY

7. 1. Purpose

To establish a robust framework for protecting ICDFA's data, applications, and infrastructure within cloud environments. It aims to ensure the confidentiality, integrity, and availability (CIA) of all information used for online classes, student records, and operational data.

7. 2. Scope

This applies to all ICDFA students, staff, and third-party contractors who access, manage, or interact with our cloud services. This includes, but is not limited to,

7.2.1. Online Learning Platforms: All cloud-based systems used for virtual classrooms, course materials, and student portals

7.2.2. Data Storage: Cloud storage solutions where student records, financial information, and research data are held.

7.2.3. SaaS, IaaS, and PaaS: Any third-party "Software as a Service," "Infrastructure as a Service," or "Platform as a Service" applications used by the academy.

7.3. Roles and Responsibilities:

7.3.1. Cloud Service Owners: They are responsible for the specific cloud service, including vendor management and ensuring it complies with this policy.

7.3.2. IT Department: The team is responsible for reviewing, approving, and assisting in the secure configuration and integration of cloud services.

7.3.3. Data Owners: They need to classify data stored in the cloud and ensure appropriate security controls are applied.

7.3.4. Users: Everyone using cloud services must adhere to security best practices.

7. 4. Policy Statements

- Approval Process: All cloud services *must* undergo a security review and approval by the IT Department before being used.
- Data Residency and Jurisdiction: Explicitly consider and document where data is stored geographically (data residency) and its legal jurisdiction, especially for sensitive data.



- Vendor Security Assessment: Cloud Service Providers (CSPs) *must* be vetted for their security practices and certifications (like ISO 27001, SOC 2).
- Shared Responsibility: Acknowledge that security is a shared responsibility between ICDFA and the CSP, and clearly define these responsibilities.
- Access Control: Access to cloud environments *must* follow ICDFA's Access Control Policy (strong authentication, least privilege, regular reviews).
- Data Encryption: All sensitive ICDFA data in the cloud *must* be encrypted both in transit and at rest.
- Logging and Monitoring: Cloud services *must* provide robust logging capabilities, integrated with ICDFA's security monitoring.
- Backup and Recovery: Critical data and applications in the cloud *must* have appropriate backup and disaster recovery mechanisms.
- Exit Strategy: A documented exit strategy *must* be in place for all critical cloud services to ensure data portability and business continuity if a service is terminated.

7.5. Compliance Requirements

This policy is imperative for adhering to the SRM (shared responsibility model) of cloud security and ensuring compliance with GDPR (Article 28, which mandates data processors to provide enough security guarantees), GLBA, and SOX for data kept in the cloud. It also aligns with the NSIT Cloud Computing Security Reference Architecture.

7.6. Enforcement and Exceptions

Unauthorized use or policy violations may result in service discontinuation, disciplinary action, or even termination. Exceptions need formal requests and approval from the IT Security Manager.

7.7. Definitions and References

- SaaS (Software as a Service): Cloud-based software delivered over the internet.
- PaaS (Platform as a Service): Cloud computing services that provide a platform allowing customers to develop, run, and manage applications.



- IaaS (Infrastructure as a Service): Cloud computing services that offer virtualized computing resources over the internet.
- CSP (Cloud Service Provider): A third-party company offering cloud-based platforms, infrastructure, applications, or storage services.

References:

- Enterprise Security Policy, Data Classification Policy, Access Control Policy.
- Shared Responsibility Model: This is a security model sharing duties between the customer and the provider of cloud services.
- Related Documents: Data Classification and Handling Policy, Incident Response Plan.

7. 8. Version Control and Review

Document Reference No: ICDFA/CS/SP/2025/01

Effective Date: August 2025

Next Review Date: August 2026

Review Schedule: Annually or when new cloud services are adopted or significant changes occur in existing cloud environments.

Policy Owner: Information Security Officer

Approved By: Board of Directors and Chief Information Security Officer (CISO)

Version: v1.0

7. 9. Verification and Metrics

- Security Assessment Reports: Reviewing vendor security assessment and audit reports.
- Compliance Audits: Conducting regular audits of cloud service configurations against ICDFA policies.
- Incident Reports: Tracking security incidents related to cloud services.
- Log Analysis: Analyzing logs from cloud services for anomalies.



8. 0. PHYSICAL SECURITY POLICY

8. 1. Purpose:

To protect ICDFA's physical assets and facilities from malicious access, theft, damage, and environmental threats. This policy applies to all the academy's buildings, labs, data centers, and IT equipment.

8. 2. Scope:

This applies to all individuals who enter ICDFA's physical premises, including staff, students, and visitors. It is inclusive of all physical locations owned by ICDFA, such as

8.2.1. Academy Buildings: All offices, classrooms and administrative areas

8.2.2. Server Rooms: All on-premises data centers and network closets.

8.2.3. Assets: All physical equipment, including servers, computers, and networking devices.

8.3. Roles and Responsibilities

These include

8.3.1. Facilities Management: They are responsible for implementing and maintaining physical security controls (e.g., locks, cameras, alarms).

8.3.2. Security Personnel: This team monitors systems, responds to incidents, and enforces access controls.

8.3.3. All Users: Everyone must follow procedures, challenge unauthorized individuals, and report suspicious activities.

8.3.4. IT Department: Responsible for securing IT equipment within the physical facilities.

8. 4. Policy Statements

8.4.1. Access Control to Facilities:

- Entry Points: All entry points to ICDFA facilities must be secured and monitored.
- Identification: All individuals must display appropriate ICDFA identification (e.g., ID badge) while on premises. Visitors must be escorted.



- Access Credentials: Access cards/keys must not be shared and must be reported if lost or stolen immediately.
- Tailgating/Piggybacking: Explicitly prohibited.
- Restricted Areas: Critical areas such as server rooms, data centers, and network closets must have enhanced physical access controls (e.g., biometric scanners, separate keycard access) and continuous monitoring.
- Surveillance: Security cameras will be deployed in strategic locations to monitor entry points, common areas, and restricted zones. Recordings will be retained for a specified period.
- Environmental Controls: Facilities housing critical IT equipment must have appropriate environmental controls (e.g., HVAC, fire suppression, uninterruptible power supplies—UPS) to protect against damage.

8.4.2. Equipment Security:

- Asset Tagging: All ICDFA equipment must be clearly tagged and inventoried.
- Theft Prevention: Equipment must be physically secured where feasible (e.g., cable locks for laptops, bolted-down servers).
- Disposal: Secure disposal procedures must be followed for all retired equipment containing ICDFA data.

8.4.3. Emergency Procedures: Clear emergency procedures for fire, power outages, and other physical threats must be established and communicated.

8. 5. Compliance Requirements

This policy helps ICDFA meet the physical safeguards of HIPAA (for health-related information) and PCI DSS (Requirement 9 on restricting physical access to cardholder data). NSIT's physical and environmental safety control is included in this compliance.

8. 6. Enforcement and Exceptions

Violations of this policy, including unauthorized entry or tampering with physical security measures, may result in disciplinary action, up to and including termination of employment, as well as potential legal action. Exceptions need explicit approval from Facilities Management and the IT Security Manager.



8.7. Definitions and References

- Physical Assets: Tangible items owned by ICDFA, including buildings, equipment, and hardware.
- Restricted Area: Any area requiring special authorization for entry due to the sensitive nature of its contents.

References:

- Enterprise Security Policy, Incident Response Policy.
- Secure Area: Any location that keeps or holds sensitive IT assets and confidential data.
- Related Documents: Access Control Policy, Incident Response Plan.

8.8. Version Control and Review

Document Reference No: ICDFA/PH/SP/2025/01

Effective Date: August 2025

Next Review Date: August 2026

Review Cycle: Annually, or upon significant changes to facilities, equipment, or security incidents.

Policy Owner: Information Security Officer

Approved By: Chief Information Security Officer (CISO) and Board of Directors

Version: v1.0



EFFECTIVE METRICS AND MEASUREMENT

1. Compliance Metrics: Adherence to policy will be measured through
 - a) Audit Scores: The percentage of controls found to be compliant during audits.
 - b) Access Control Logs: The number of malicious or unauthorized access attempts to physical and cloud assets.
 - c) Exceptions Rate: The number of policy exceptions requested and approved, which can indicate if a policy is overly restrictive.
2. Security Incident Metrics: Incidents will be tracked to measure the policy's impact on reducing risk.
 - a) Incident Count: The total number of security incidents related to physical or cloud assets.
 - b) Mean Time to Contain (MTTC): The average time it takes for the security team to detect and contain an incident after it occurs. A decrease in MTTC indicates a more effective response plan.
3. Awareness and Understanding: Employee knowledge and understanding will be assessed.
 - a) Phishing Simulation Results: The percentage of employees who fall for simulated phishing attacks. A decrease indicates improved awareness.
 - b) Training Completion Rate: The percentage of employees who complete mandatory security training on time.
4. Risk Reduction Metrics: Changes in risk levels will be measured using risk assessment tools.
 - a) Vulnerability Scan Report: The number of critical vulnerabilities discovered on systems. A decrease suggests that proactive security policies are effective.
 - b) Risk Score: A quantitative or qualitative score assigned to the overall security standard, which should decrease over time as policies are implemented and mature.



IMPLEMENTATION STRATEGIES AND EFFECTIVENESS MEASUREMENT

1. **Communication Campaign:** Policies will be communicated simultaneously using several routes to reach all stakeholders. This applies to an all-staff email from the CISO and leadership, town hall meetings, and a specific section on the company intranet with easy-to-understand summaries and Frequently Asked Questions (FAQs). The why of the policies will be communicated in order to foster rapid buy-ins and understanding of them.

2. Training and Education:

Training will be mandatory and tailored to different audiences.

- a) All employees will undergo a mandatory online training module covering key policies, including strong passwords, phishing recognition, and physical access rules.
- b) IT and Security Teams: Technical controls, incident response protocols, and policy enforcement will be the subjects of specialized, in-depth training for the IT and security teams.
- c) Contractors and Vendors: They will be required to take and complete a security awareness module specific to their access level.

3. Leadership Support: Leadership buy-in and support will be secured early in the process.

The CISO will present the policy to senior management, emphasizing how it directly mitigates business risks and aligns with ICDFA's strategic goals. Once approved, leaders will publicly support the policy and lead by example by adhering to all the requirements.

4. Gradual Deployment:

The policy will be gradually implemented to reduce the impact and time for adaptation.

- a) **Phase 1 (Pilot):** Deploy policy to a single department or a small group of systems to work out any unforeseen issues.
- b) **Phase 2 (Lessons Learned Wider Rollout):** Deploy the policy to all departments, including all your assets, after success is measured. This is to include planned system upgrades or security controls configuration.



5. Supporting Tools: To aid compliance, templates and tools will be provided.

- a) Security Checklist: For physical areas like server rooms and for cloud-based project launches.
- b) Policy Exceptions Request Form: A standardized online form to streamline the process for documenting exceptions.

6. Monitoring and Feedback: Compliance will be monitored continuously.

- a) Audits: Internal and external audits will be conducted regularly to verify compliance with policy requirements.
- b) Feedback: An anonymous feedback channel will be established to allow employees to ask questions or raise concerns about the policies without fear of reprisal.

7. Recognition and Incentives: Compliance will be recognized to build a positive security culture

- a) Compliance with security training will be a factor in performance reviews.
- b) Departments with the highest compliance rates will be recognized in the company.

8. Continuous Improvement:

The policy will be treated as a living document. Feedback from monitoring and audits will be used to update and refine the policy on an ongoing basis.



TRAINING AND AWARENESS

ICDFA is committed to building a culture of security awareness and readiness. This policy section outlines the framework for ensuring that all personnel, including staff, students, and affiliates, are properly trained to recognize, report, and respond to information security incidents effectively.

Training Objective

The primary objective of the training and awareness program is to equip all members of the Academy community with the necessary knowledge and skills to serve as the first line of defense against cyber threats. The program aims to ensure that all individuals understand their roles and responsibilities as defined in this policy.

Target Audience

Training is mandatory for the following groups:

- All full-time and part-time employees
- All students, upon enrollment and at specified intervals
- All contractors and third-party affiliates with access to ICDFA's systems and data
- Designated members of the Incident Response Team (IRT)

Training Curriculum

The training program will cover key topics relevant to the policy and the current threat landscape, including:

- **Policy and Procedures:** A clear overview of the Incident Response Policy, including individual responsibilities and the importance of prompt reporting.
- **Threat Recognition:** How to identify common security threats such as phishing, social engineering, malware, and other suspicious activities.
- **Incident Reporting:** A detailed guide on how to properly use the Security Incident Form on the IT Help Desk portal and when to use the critical threat hotline. The training will emphasize the no-blame culture to encourage transparent reporting.
- **Data Protection:** Best practices for handling, storing, and transmitting sensitive information in compliance with the NDPA 2023.



- Secure Computing Habits: Guidelines for creating strong passwords, managing access, and practicing safe browsing.

Program Metrics and Review

The effectiveness of the training and awareness program will be continuously monitored and measured. Metrics will include:

- Completion rates of mandatory training modules.
- Success rates of phishing simulations and incident response drills.
- Results from periodic surveys and quizzes to assess understanding.
- Incident metrics from the incident log which may show a reduction in common, human-error-related incidents over time.

REFERENCES

- ICDFA Information Security Policy: This policy is a foundational document that outlines the overall security posture and principles of the organisation.
- Data Classification and Handling Policy: The document that defines how different types of data are classified and how they must be handled to ensure their confidentiality, integrity, and availability.
- Disaster Recovery Plan (DRP) & Business Continuity Plan (BCP): Related plans that provide procedures for resuming business operations and recovering systems and data after a major disruption.
- Applicable Legal and Regulatory Requirements: All relevant laws, regulations, and contractual obligations, including but not limited to the Nigeria Data Protection Act (NDPA) and other industry-specific compliance standards (e.g., ISO 27001).



13. CONCLUSION

The adherence to this Incident Response Policy is critical for protecting ICDFA's information assets, maintaining business continuity, and upholding the trust of our stakeholders. By defining clear roles, implementing robust procedures, and fostering a culture of timely reporting, we can effectively minimize the impact of security incidents. This policy is an essential component of ICDFA's commitment to digital resilience and a secure operating environment. It is the responsibility of every employee to understand and comply with these provisions to ensure the safety and security of the entire organisation.



Appendices

Revision History Table

Version	Date	Description of Change	Reviewer

Exception Request Form

Exception Request Form		
<i>Confidential when completed</i>		
Section 1: Exception		
1.1 Requestor Information		
Name:	Phone:	Date:
Department:		
Email:		
1.2 Exception Details		
Policy Reference:	Standard Reference:	Exception End Date: (no more than one year)
Entity Impacted:		
System(s) Hardware Impacted (if applicable):		
Will this impact the process, stage and/or transmission of PII? Yes ____ No ____		
1.3 Reason for Exception Request		



1.4 Description/Assessment Risk		
1.5 Compensating Controls (to mitigate risk associated with non-compliance)		
1.6 Corrective Action Plan		
Section 2: Requestor Authorizations		
2.1 Department Owner:	Signature_____	Date:
	Department Owner	
2.2 Security Manager:	Signature_____	Date:
	Security Manager	
Return to: [email]	[address]	
Section 3: Exception Approval/Denial (ICDFA DIRECTOR Use Only)		
Exception: ___ Approved ___ Denied	Proposed Review Date:	
Reason for Denial:		



3.1 ICDFA Director:		Date:
---------------------	--	-------